Log4j安全漏洞的云主机场景响应实践

2021年12月28日Apache Log4j2官方公布了最新的Apache Log4j2远程代码执行漏洞（CVE-2021-44832）。安天第一时间对此进行了分析，其主要原理是当攻击者有权限修改日志配置文件，并恶意修改JDBCAppender的数据源，可造成JNDI注入实现远程代码执行。

Apache Log4j2 远程代码执行高危漏洞爆发以来，各个安全厂商陆续推出了针对此漏洞的修复方案和工具。修复方法包括如下：

1、 根据官方建议将Apache Log4j2更新到最新版本，详见地址：https://logging.apache.org/log4j/2.x/security.html

2、 彻底手工移除Log4j2中带JNDI的相关class文件

3、 设置一些环境变量，以防止Log4j2调用到JNDI

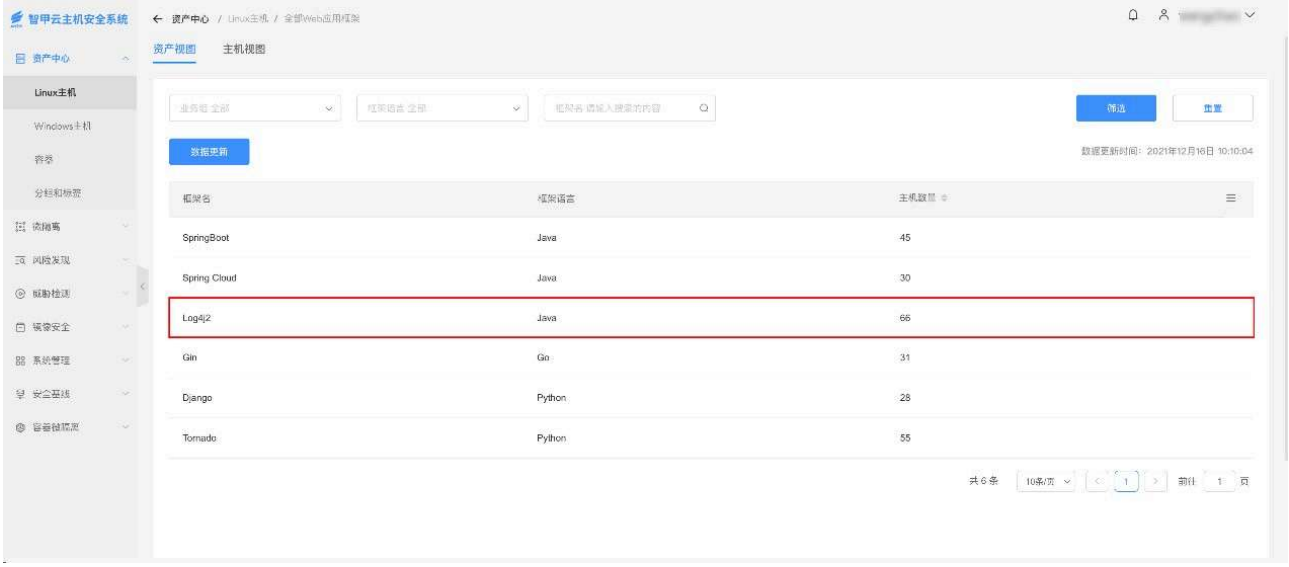
4、 其它一些手工工具修复等等

但是对于云主机以及容器这样的工作负载来说，目前的大多数修复方案多少都存在一些不尽如人意的地方，尤其是安全运维人员面对海量的工作负载时，需要更加自动化、智能化的解决方案。安天云安全团队第一时间推出面向云计算环境的整体安全解决方案。本方案针对Log4j 2的漏洞问题，在云场景下从威胁对抗的角度提供了识别、加固、防御等的相关具体措施。

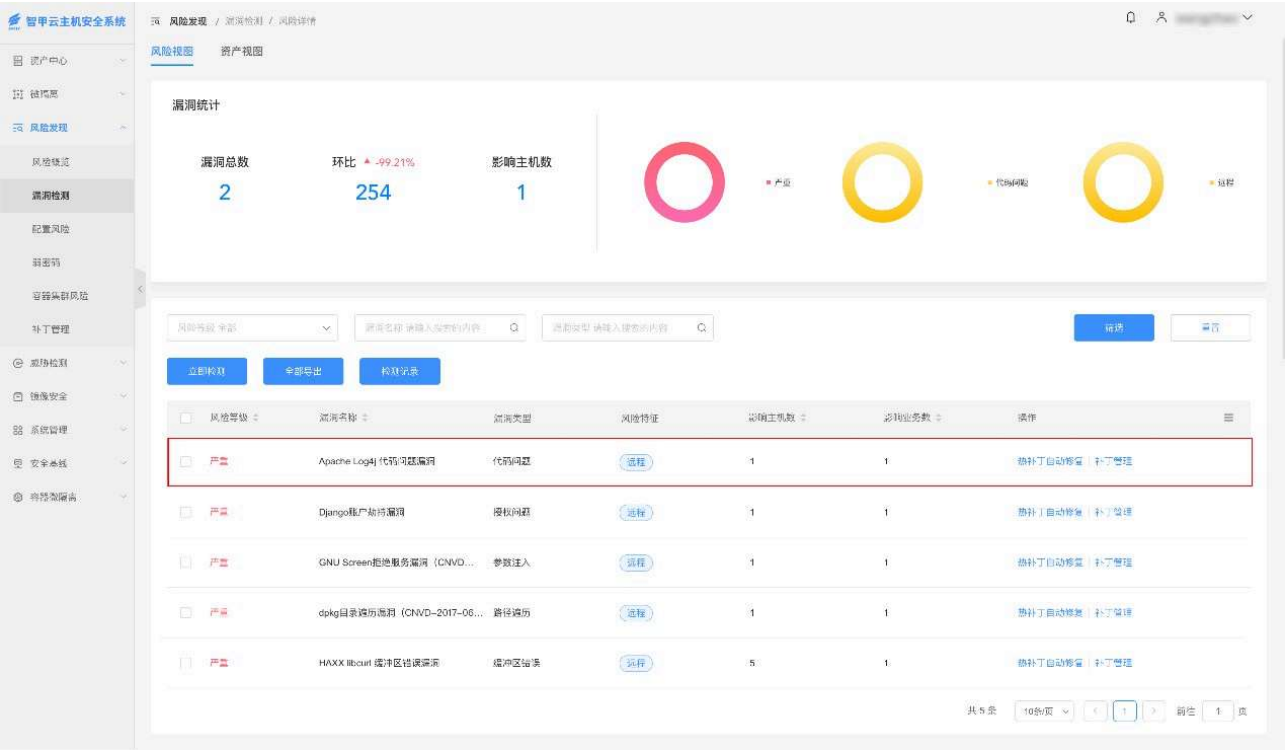
2.快速高效清点Log4j2漏洞资产

如何判断资产中是否存在Log4j 2漏洞？人工查找包含引用相关class文件包的应用费时费力容易疏漏。使用智甲云主机安全系统，通过在多云、混合云环境中各类工作负载统一的细粒度资产清点和风险发现等功能，可以实现隐患资产的快速排查并及时告警。下面是相关操作方法：

1. 主机资产识别



2. 漏洞扫描



3. 基线核查

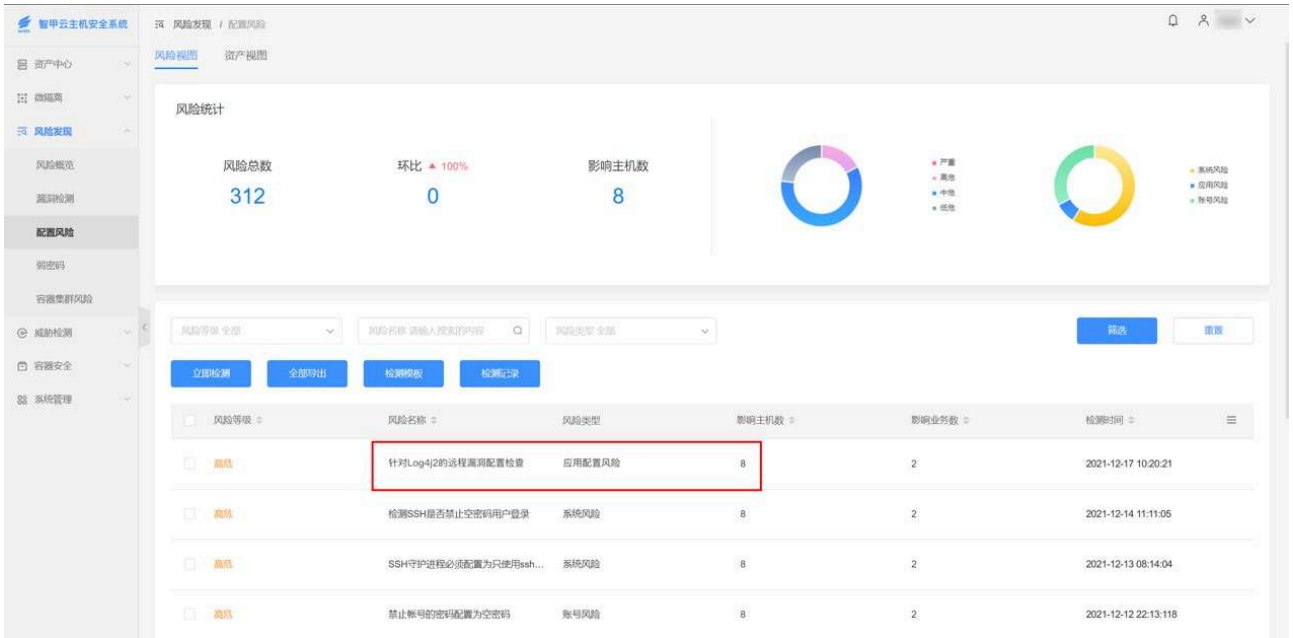
目前较为流行的应急缓解措施有如下几种方式：

1) 添加log4j2.component.properties配置文件，增加：log4j2.formatMsgNoLookups=true

2) 设置jvm启动参数: -Dlog4j2.formatMsgNoLookups=true

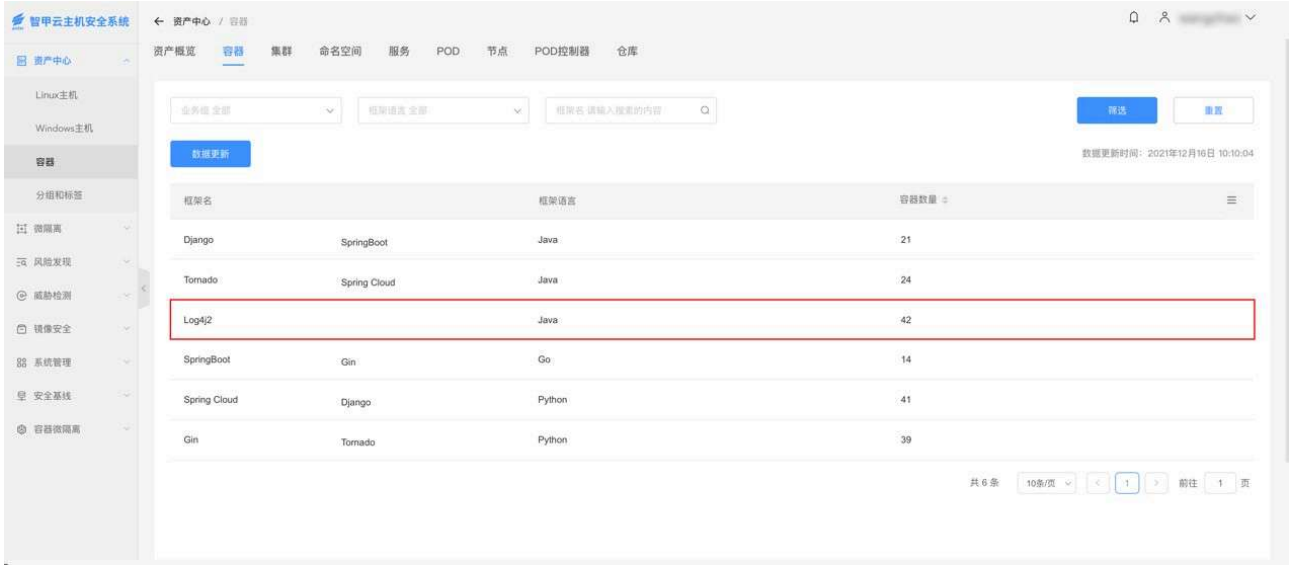
3) 设置系统环境变量：LOG4J_FORMAT_MSG_NO_LOOKUPS=true

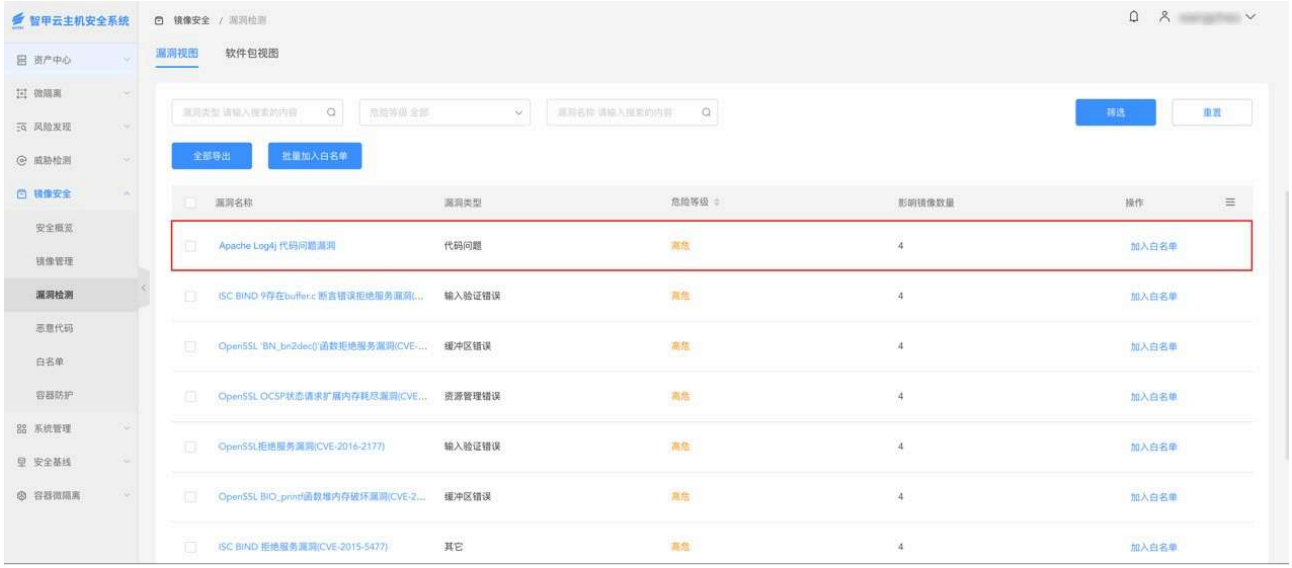
除此之外，安全运维人员还可通过资产基线核查的功能，详细理出存在风险的资产，确保修复计划覆盖所有风险资产。

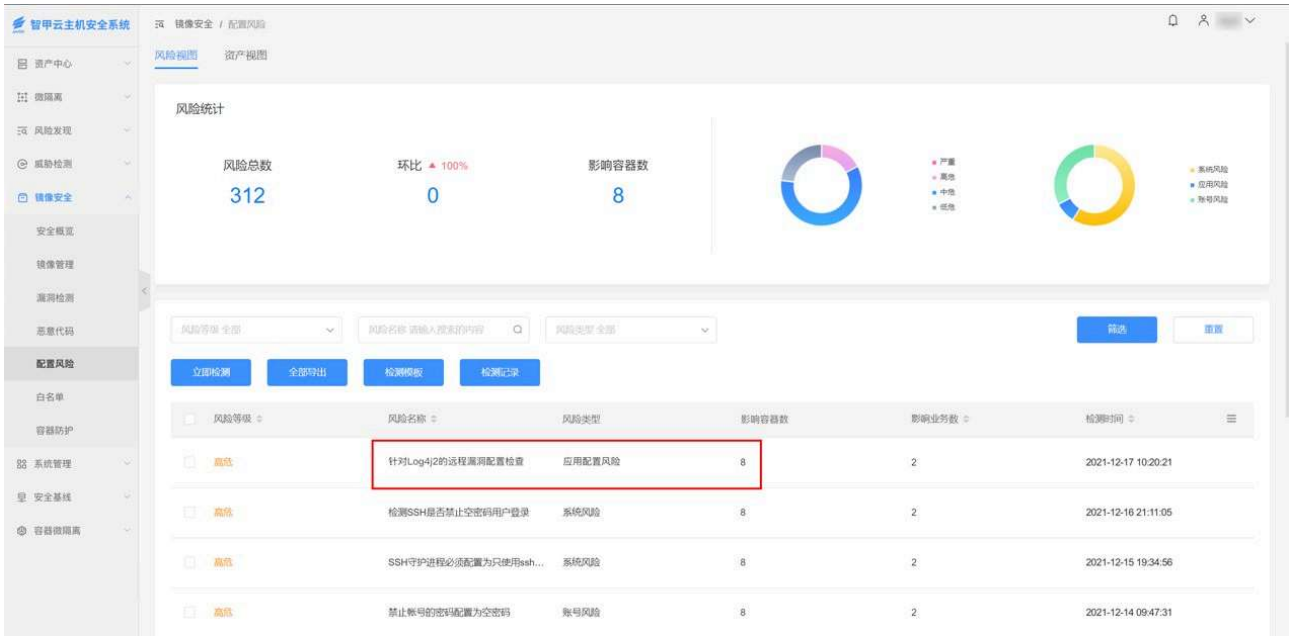


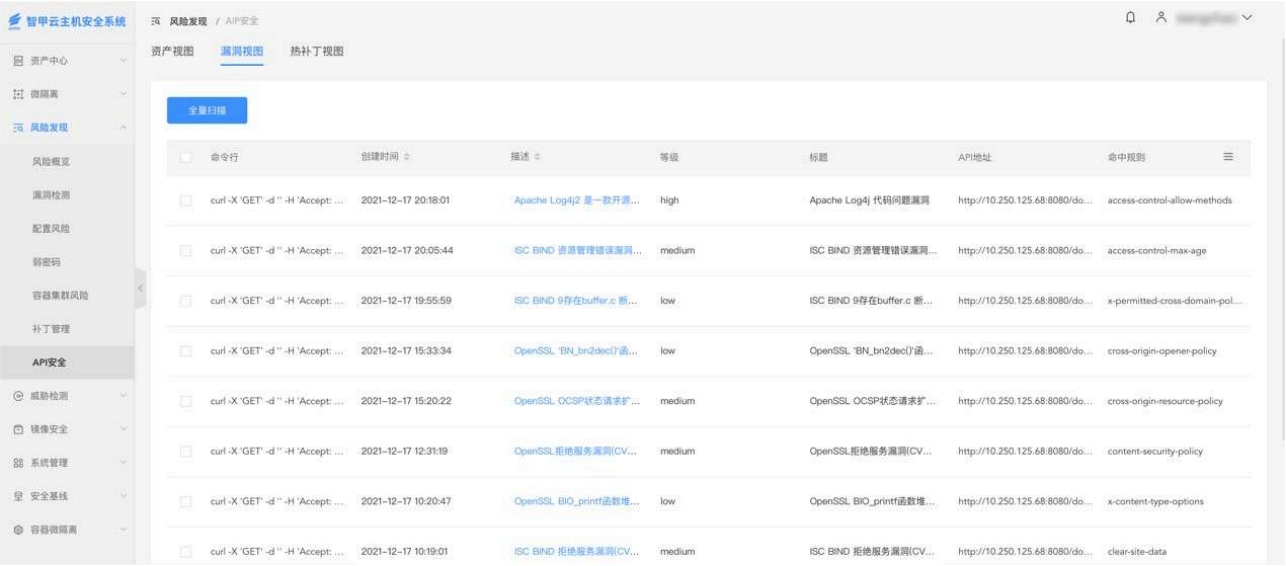
4. 容器云环境下的排查方法

安天智甲容器安全系统可以在容器构建阶段，通过对本地镜像和镜像仓库进行漏洞与安全基线检测，及时发现Log4j 2安全风险，并可以通过设置策略阻止含风险镜像启动；在容器运行阶段，可以对运行中的容器进行风险扫描，确认线上容器是否已经存在风险，同时API安全功能可以自动发现、自动扫描线上的微服务API是否存在安全风险。


智甲云主机安全系统
资产中心 / 容器
资产概览 容器 集群 命名空间 服务 POD 节点 POD控制器 仓库
筛选 重置
数据更新
数据更新时间：2021年12月16日 10:10:04
框架名 框架语言 容器数量
Django SpringBoot Java 21
Tornado Spring Cloud Java 24
Log4j2 Java 42
SpringBoot Gin Go 14
Spring Cloud Django Python 41
Gin Tornado Python 39
共 6 条 10条/页 前往 1 页


智甲云主机安全系统
镜像安全 / 漏洞检测
漏洞视图 软件包视图
筛选 重置
全部导出 批量加入白名单
漏洞名称 漏洞类型 危险等级 影响镜像数量 操作
Apache Log4j 代码问题漏洞 代码问题 高危 4 加入白名单
ISC BIND 9存在buffer.c 断言错误拒绝服务漏洞(... 输入验证错误 高危 4 加入白名单
OpenSSL `BN_bn2dec()`函数拒绝服务漏洞(CVE-... 缓冲区错误 高危 4 加入白名单
OpenSSL OCSP状态请求扩展内存耗尽漏洞(CVE... 资源管理错误 高危 4 加入白名单
OpenSSL拒绝服务漏洞(CVE-2016-2177) 输入验证错误 高危 4 加入白名单
OpenSSL BIO_printf函数堆内存破坏漏洞(CVE-2... 缓冲区错误 高危 4 加入白名单
ISC BIND 拒绝服务漏洞(CVE-2015-5477) 其它 高危 4 加入白名单


智甲云主机安全系统
镜像安全 / 配置风险
风险视图 资产视图
风险统计
风险总数 312
环比 100% 0
影响容器数 8
筛选 重置
立即检测 全部导出 检测模板 检测记录
风险等级 风险名称 风险类型 影响容器数 影响业务数 检测时间
高危 针对Log4j2的远程漏洞配置检查 应用配置风险 8 2 2021-12-17 10:20:21
高危 检测SSH是否禁止空密码用户登录 系统风险 8 2 2021-12-16 21:11:05
高危 SSH守护进程必须配置为只使用ssh... 系统风险 8 2 2021-12-15 19:34:56
高危 禁止帐号的密码配置为空密码 账号风险 8 2 2021-12-14 09:47:31



3.批量加固修复、规避风险

Log4j2漏洞利用有5个主要步骤：

1. 向存在Log4j2漏洞的服务端发送http包头，其中含有JNDI lookup的恶意请求；

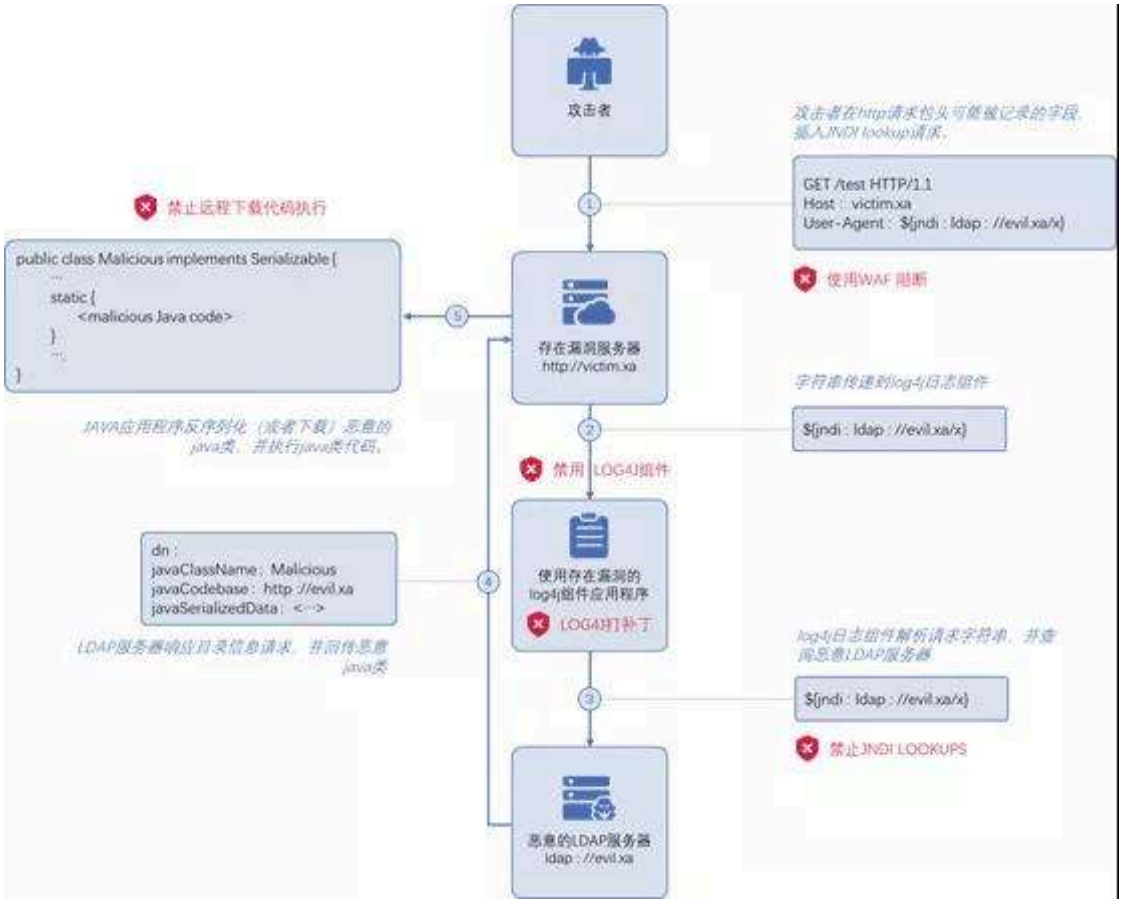
2. 服务端解析请求，并将恶意字符串传递至Log4j2组件；

3. Log4j2组件解释执行恶意字符串中内容，外联至恶意服务器；

4. 恶意服务器回传恶意Payload；

5. Log4j2漏洞服务端JAVA应用反序列化（或者下载）恶意JAVA类并执行；

具体的漏洞利用步骤以及每个步骤的常见防御手段，如下图所示：

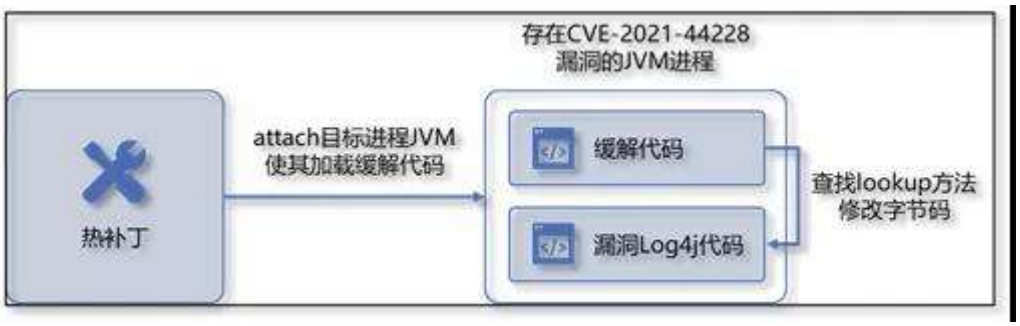


攻击者想要利用该漏洞，需要至少执行上述5个步骤。任一步骤执行不成功，都可以阻断攻击，从而实现安全加固效果。

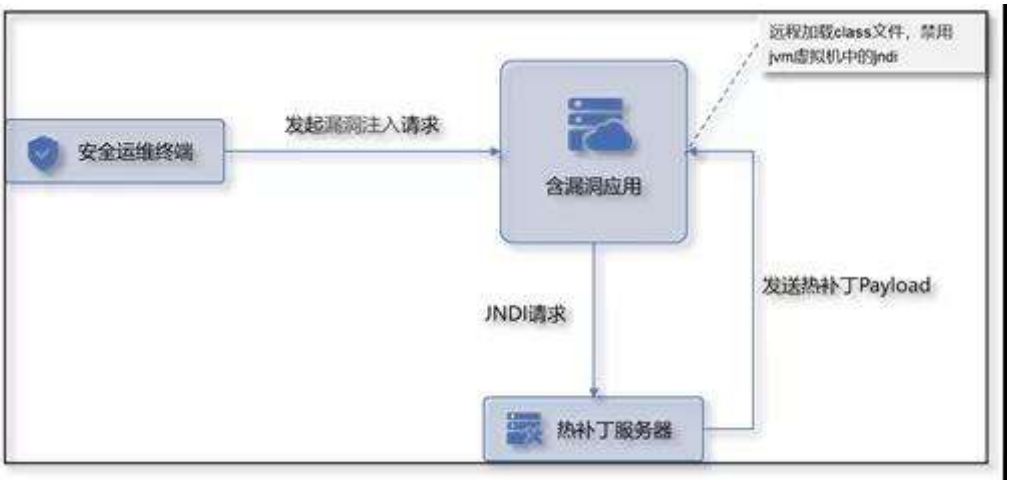
目前，网络上已经公开多种WAF绕过方式，单纯使用WAF阻断很难达到效果。而禁用Log4j2组件容易造成业务系统故障，尤其是老旧系统故障。热补丁方案可实现批量化处置，并且无需重启java服务，不会对业务系统造成影响，是目前较为可行的临时解决方案。

安天云安全为主机场景、容器场景分别提供了相应的热补丁方案，其原理如下：

1. 主机热补丁原理是借助JVM的Attach机制, 将缓解代码注入运行中的目标JVM进程, 再使用ASM（Java 字节码操控框架）修改JVM中的org.apache.logging.log4j.core.lookup.JndiLookup方法的字节码, 达到无需重启禁用JndiLookup::lookup的目的。

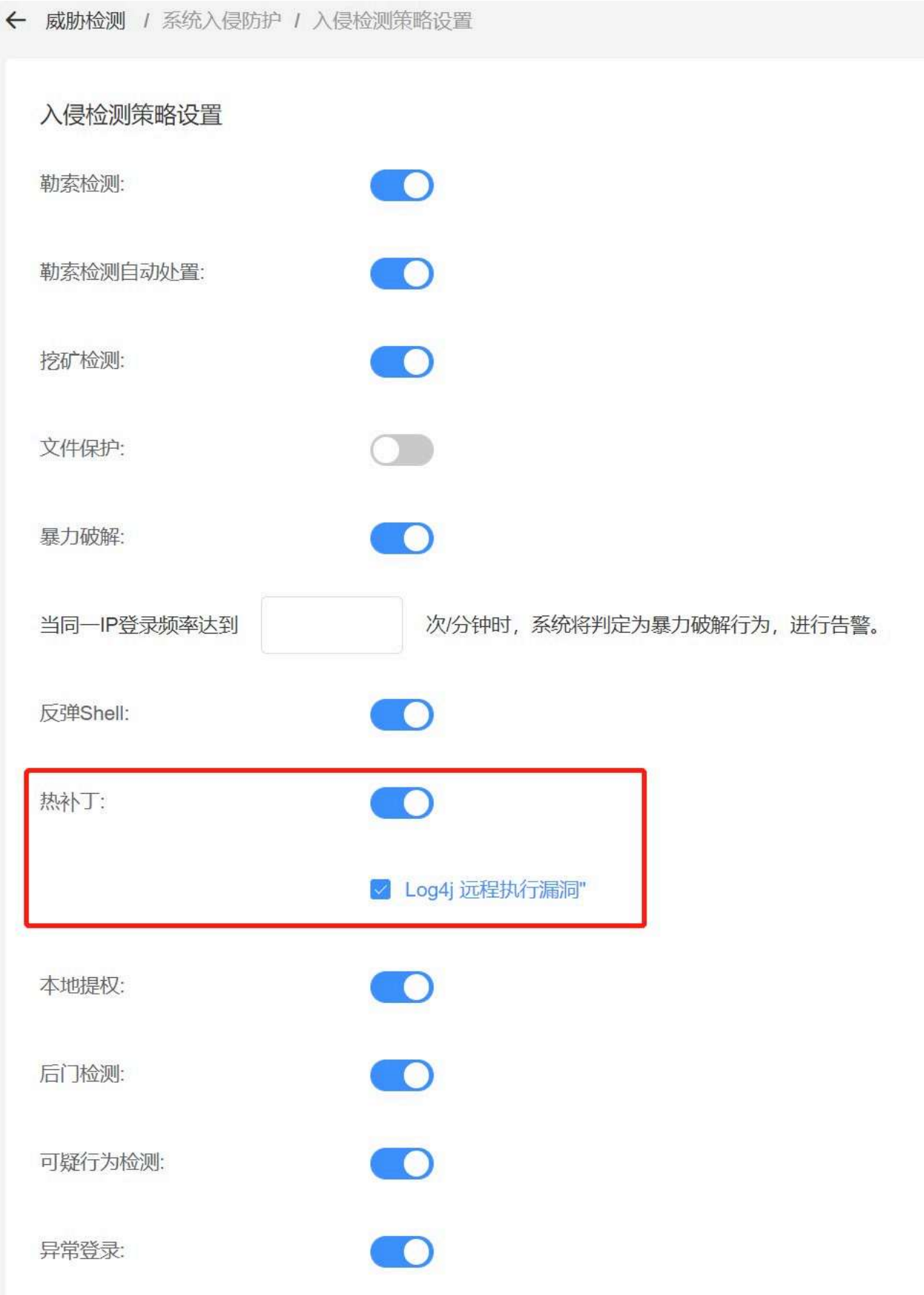


2. 容器热补丁原理是利用漏洞注入点，把注入payload修改为安全服务器热补丁地址，存在漏洞的应用会从安全服务器热补丁地址远程加载class文件，最终实现无需重启服务来禁用jvm虚拟机中的JNDI。



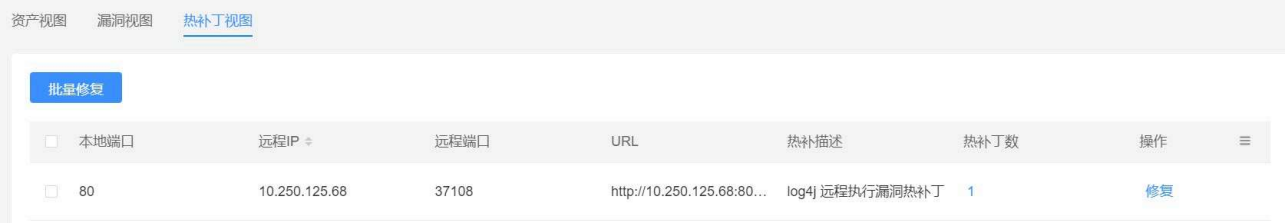
根据以上的原理，我们对主机和容器提供可自动修复漏洞的热补丁功能，可以自动、手动加固存在漏洞的应用。

1. 云主机自动化热补丁加固



在主机/云主机上，探针将实时检测任何启动的JAVA应用，并且检测其是否包含Log4j2漏洞，如果存在则立即注入并消除潜在风险。安全运维人员可以开启或者关闭这个策略。

2. 容器自动化热补丁加固

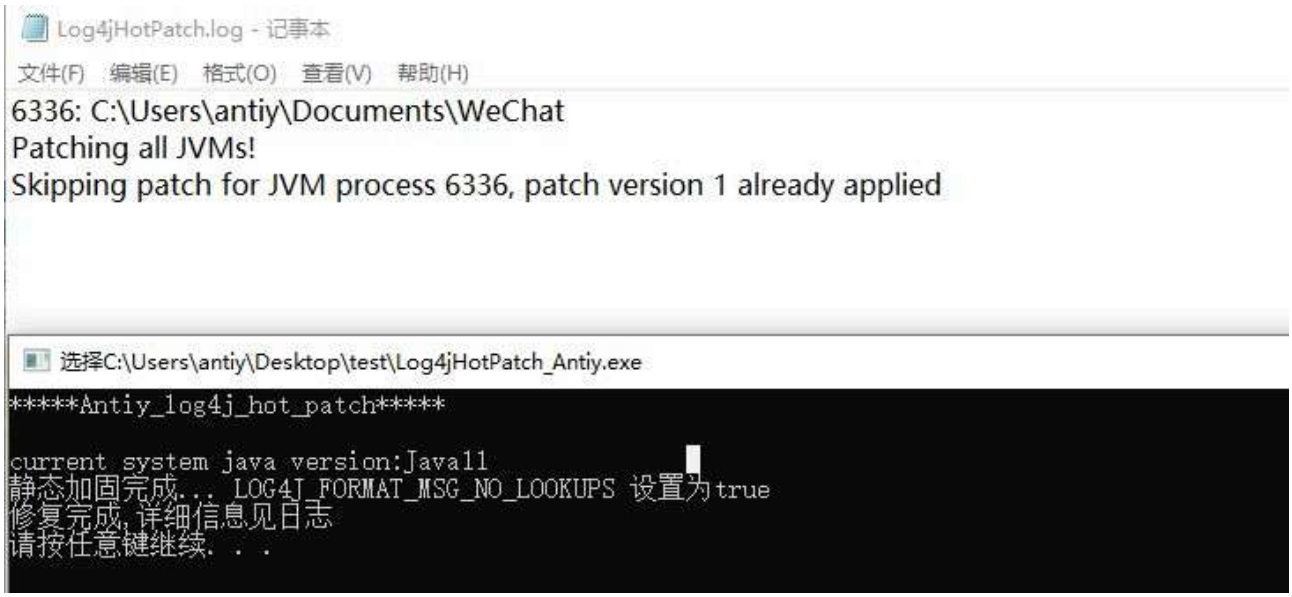


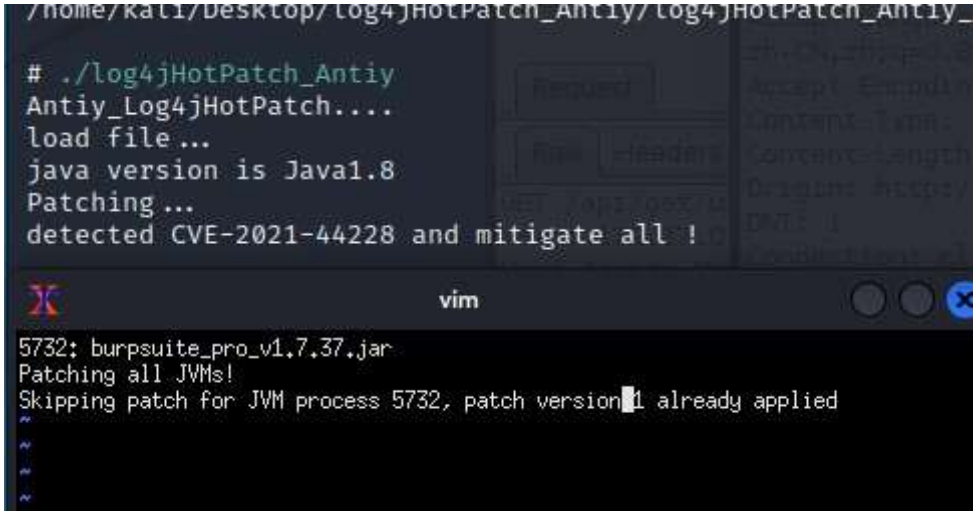
在容器云环境下，通过API自动发现功能，可以发现线上运行时容器存在的Log4j2漏洞，修复的方式是通过Log4j2漏洞exp将管理中心上的热补丁打入目标机执行。安全运维人员可以使用一键批量修复功能，快速给容器进行热修补。

3. 手动热补丁加固

若小伙伴们没有在使用安全智甲云主机系统，可联系安天客服中心电话：4008409234或扫描下方二维码，添加客服微信获取。

具体操作如下图所示：





注：热补丁在业务重启后将失效，需重新打热补丁。

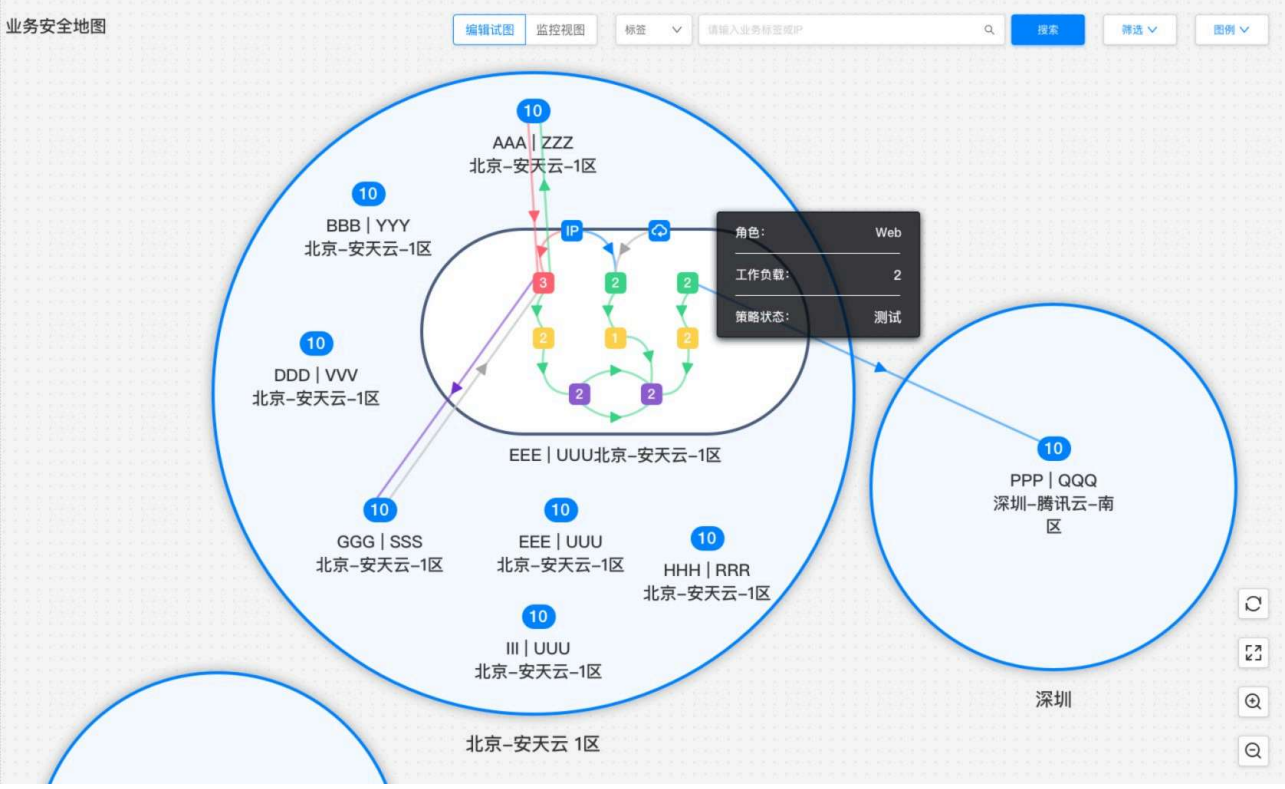
4.漏洞防御和应对

Log4j2漏洞攻击的关键步骤在于受攻击的服务应用通过网络访问了非授信的外部资产，然后下载并执行攻击载荷。因此，如何在复杂主机环境中，尤其是云环境中构建一个可信的网络访问策略，是避免遭受此类0day攻击的一个重要措施。而这也是零信任框架中的核心理念：构造应用访问的最小依赖关系，并通过持续认证的技术手段，限制攻击者的横向移动范围并减小攻击面。如今微隔离技术已成为保护企业业务免受破坏的最佳实践之一，其主要的价值在于迫使攻击者（和恶意软件）“付出超额的技术和人力成本”。在最好的情况下，微隔离可以直接消除威胁。在最坏的情况下，所有额外的活动都会增加防御者发现的机会。

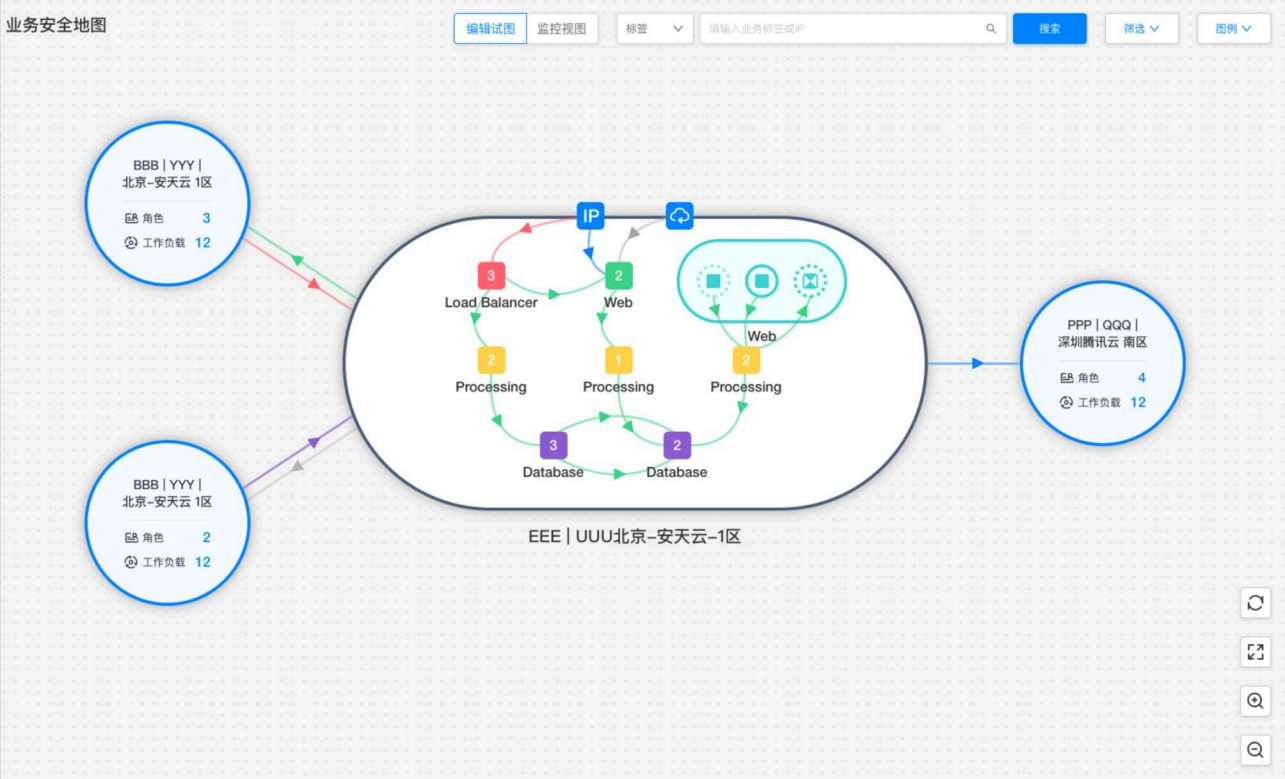
此外，根据Log4j2 社区提供的信息，认为Log4j 1.X 版本也会因JNDI的支持受到漏洞影响。但鉴于已经停止维护，不会发布相关更新，相关漏洞如：CVE-2021-4104。

我们推荐采用安天云主机安全系统的微隔离解决方案：

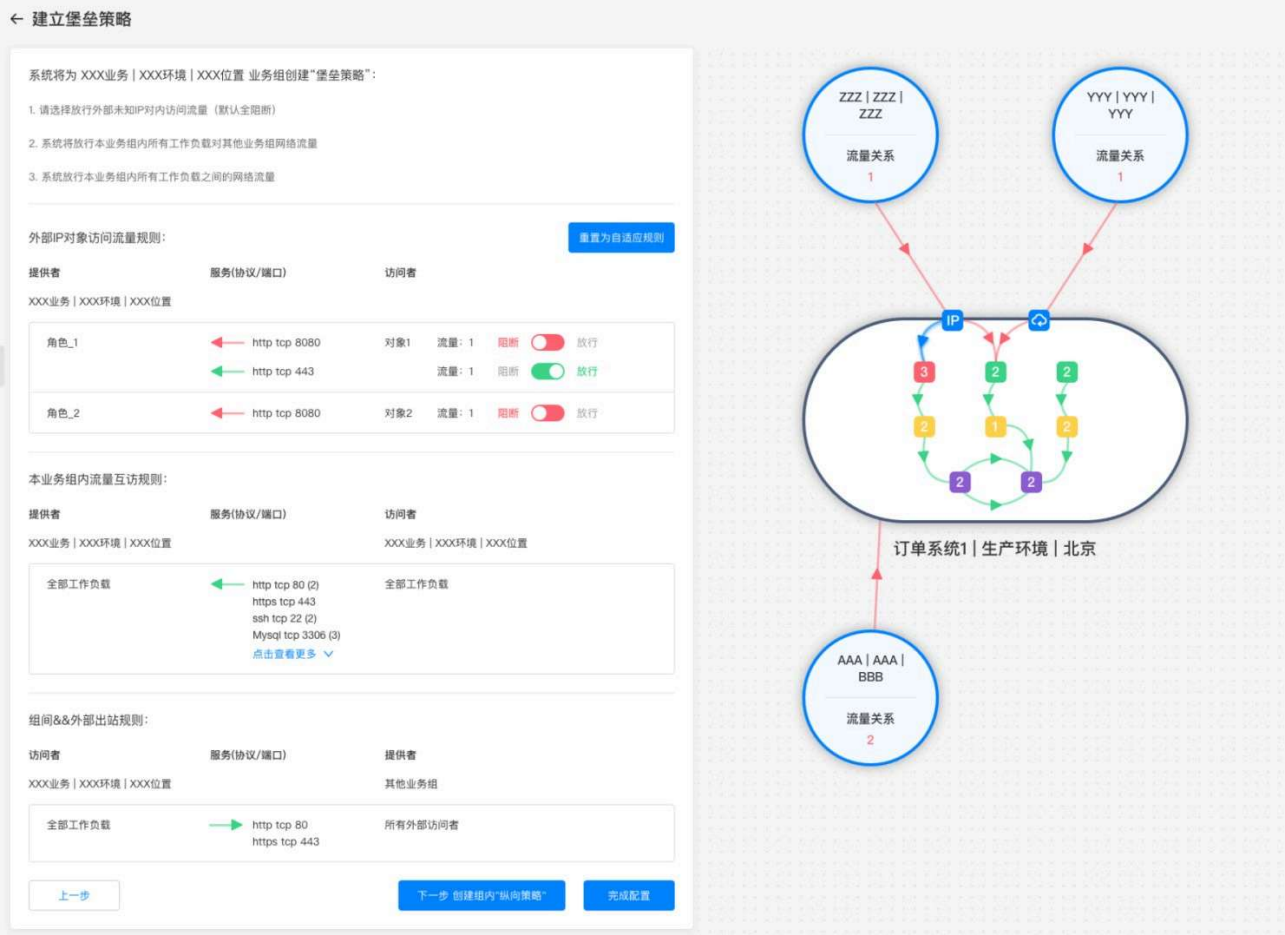
1、 自动化的云上资产应用的识别，以及智能化的映射工作负载、应用程序和环境之间的连接。



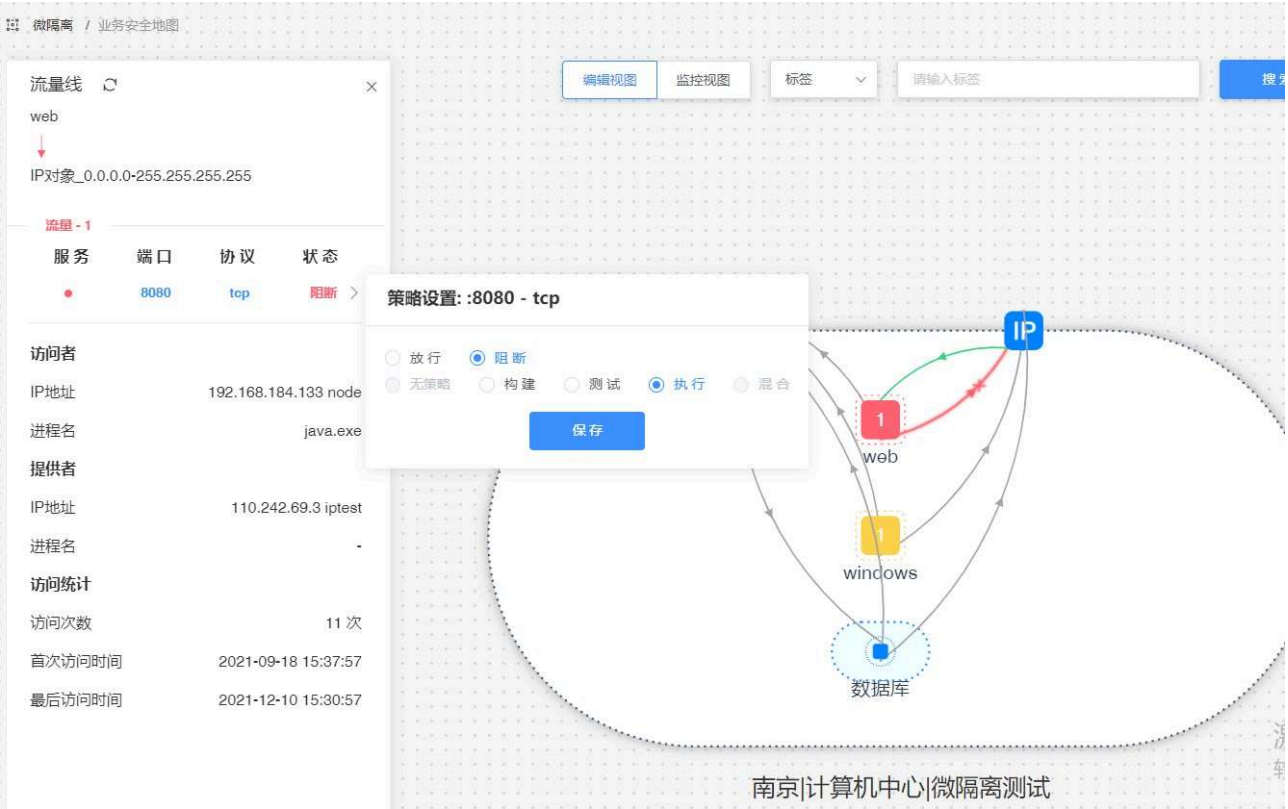
2、 理解安全隔离的原则，并根据运营安全需求制定合理的、不同粒度的微隔离策略。



3、 测试并部署微隔离策略，通过测试和构建访问模型，确保该策略与数据中心的运作方式保持一致，在业务和应用层面以透明状态存在，对其没有任何影响。



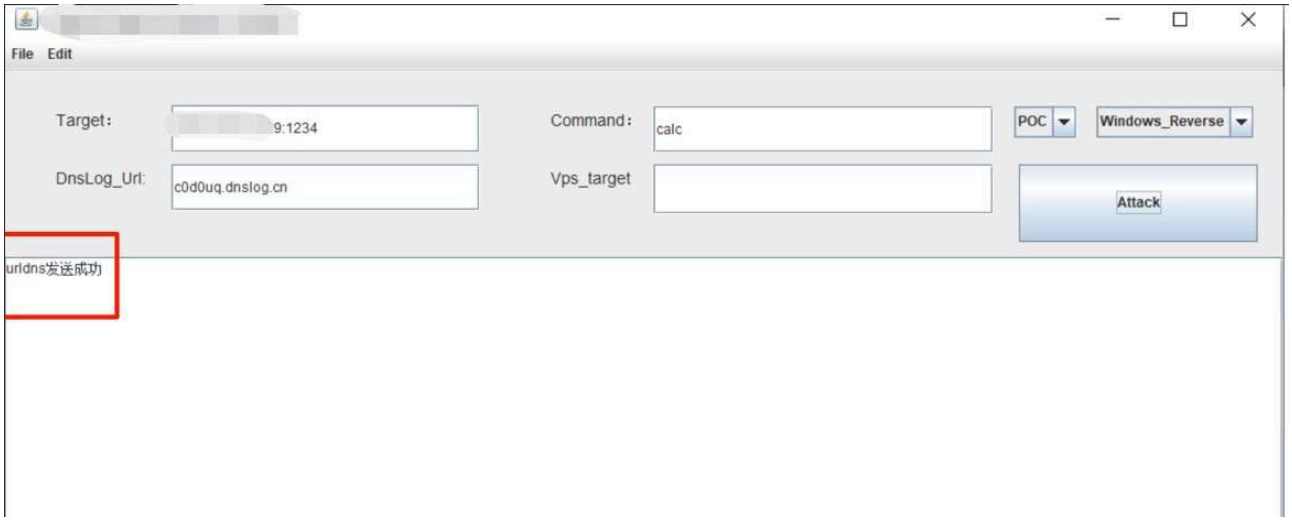
最终根据零信任安全最佳实践，对用户全网业务流量实施“持续认证，非授权，不放行”的网络安全策略。将使得上述场景中攻击者（通过RCE等方式）在访问额外的网络资源时及时阻断，或者洞察非授权的网络访问行为及时告警。通过限制攻击者的网内横向移动行为，从而规避或者缓解失陷主机带来的威胁面扩散的风险。



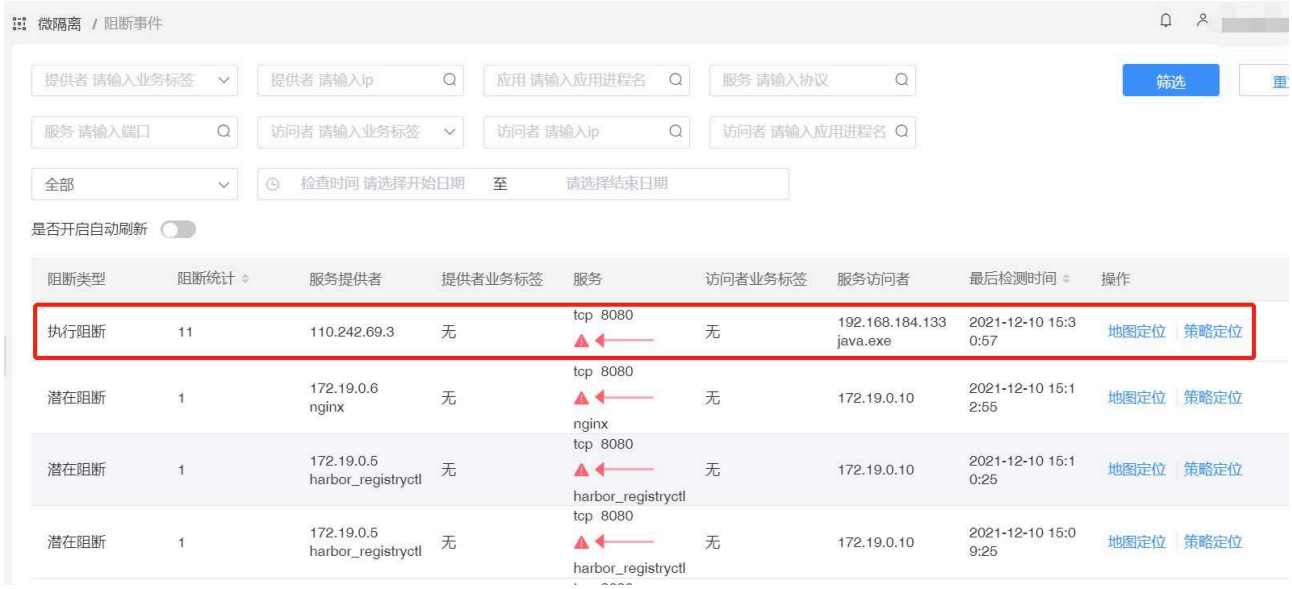
5.防御有效性验证

微隔离防御验证：

1. 启动POC测试工具，填写相关目标及相关信息，进行验证。



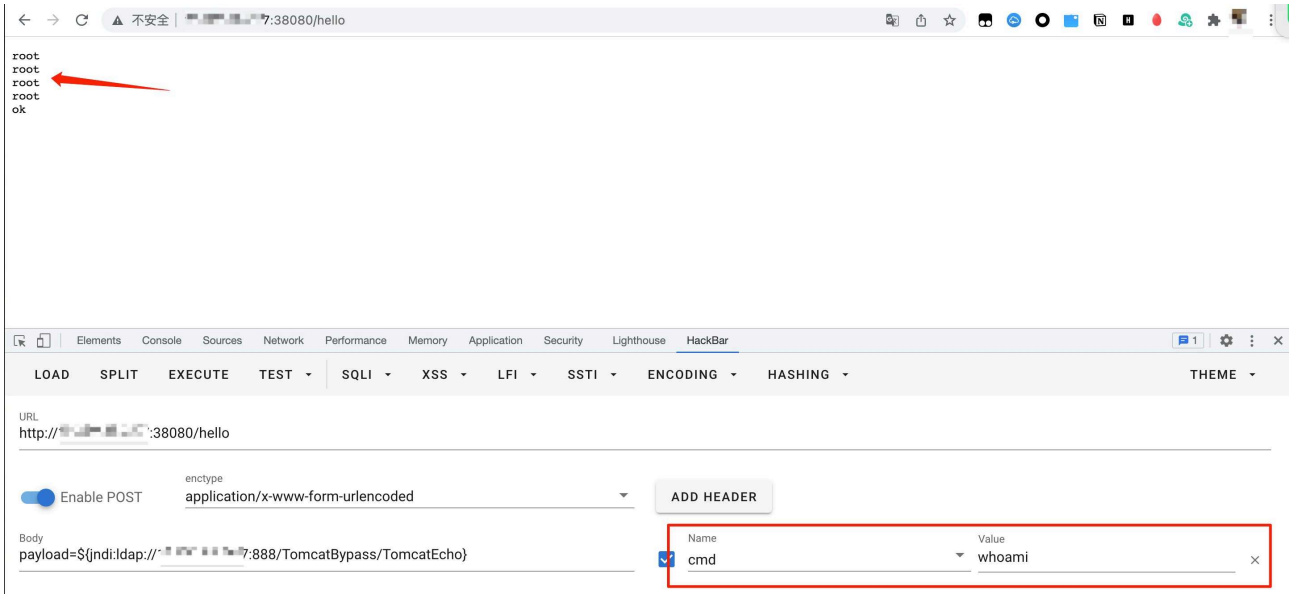
2. 在部署智甲云主机安全系统的主机上测试漏洞利用不成功，登录智甲云主机安全系统管理平台，依次点击微隔离>阻断事件，若阻断事件中存在一条记录如下图所示，证明智甲云主机安全系统已经通过流量隔离的方式将攻击行为识别并阻断。



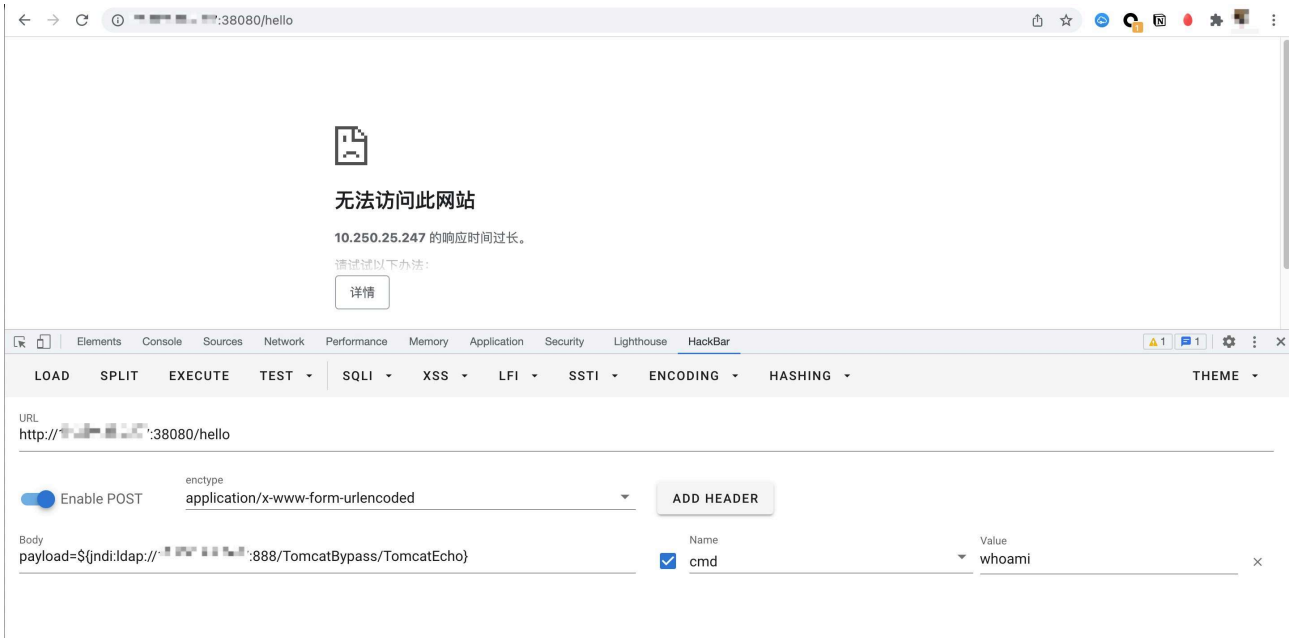
热补丁缓解验证：

1. 使用漏洞验证工具，并开启在JNDI本地服务，并确保与目标机网络互通。

2. 找到Log4j2漏洞利用点，并构造并发送POST请求，如果修补未成功，则会成功执行命令，如下图所示：



3. 反之则无任何回显，提示连接超时。证明漏洞已被修补，无法被利用成功，如下图所示：



安天云安全产品简介

安天智甲云主机安全系统是一款定位于面向多云、混合云场景下的统一云工作负载防护 产品。支持物理机、虚拟机、容器等多种工作负载，具备资产资产清点、风险评估、合规基线、入侵检测、容器安全、微隔离等10余项安全防护能力。

安天智甲容器安全系统支持多种PaaS容器云平台、容器边缘计算设备的容器安全防护产品，并同时支持deamonSet、sidecar两种方式的全容器化部署。具备容器资产清点，容器风险检测、容器运行时防护、应用入侵检测、微隔离、微服务安全等7项容器安全防护能力，覆盖容器全生命周期各阶段。

智甲云主机安全系统与智甲容器安全系统可无缝融合，为用户多云、混合云场景中的业务提供统一的、全方位的安全防护。